A Unified Framework for Operationalizing EU AI Act Compliance

Integrating Risk Management, Technical Documentation, and Human Oversight for High-Risk Systems

Hernan Huwyler, [a*]

[a] Law School Executive Education, IE University, Madrid, Spain, orcid.org/0009-0002-1249-7387
[*] Correspondence: Hernan Huwyler (hhuwyler@faculty.ie.edu; tel: + 34 915 68 96 00.).

Keywords: artificial intelligence governance, AI governance, EI AI act, high-risk AI, compliance framework, risk management, technical documentation, conformity assessment, ISO 42001, ISO 23894

JEL Codes: K24; L15; M15; O33; L86

DOI: 10.5281/zenodo.17703640 Publication Date: 24/11/2025

Abstract

The enactment of the European Union's Artificial Intelligence Act (EU AI Act) creates a pressing need for applied governance, risk, compliance, and audit (GRCA) frameworks that translate legal text into actionable corporate protocols. This research provides a comprehensive technical framework for organizations to achieve and maintain compliance, with a specific focus on the stringent obligations for high-risk AI systems and general-purpose AI models. Derived from an analysis of practitioner-oriented source material, the proposed framework structures compliance across six critical stages: Planning, Requirements, Design, Testing, Deployment, and Maintenance. The analysis shows that successful operationalization hinges on the integration of three core pillars: a continuous risk management system, meticulous technical documentation, and effective human oversight mechanisms. The paper bridges the gap between regulatory theory and practice by offering concrete steps for role identification, risk classification, and control implementation, providing immediate, actionable guidance for AI providers, deployers, and importers navigating the new regulatory landscape.

DOI: 10.5281/zenodo.17703640

1. Introduction

The global regulatory environment for artificial intelligence is undergoing a profound transformation, shifting from voluntary ethical guidelines to enforceable legal mandates. The European Union's Artificial Intelligence Act (EU AI Act) represents the world's first comprehensive legal framework for AI, establishing a risk-based regulatory paradigm with significant extraterritorial reach. This legislation imposes a complex web of obligations on a defined ecosystem of operators, Providers, Deployers, Importers, and Distributors, with non-compliance carrying penalties of up to 7% of global annual turnover. For organizations operating within or targeting the EU market, understanding and implementing these requirements is no longer a speculative exercise but a critical business imperative.

This research document addresses the central challenge facing applied GRCA professionals: moving from a theoretical understanding of the EU AI Act's articles to their practical, day-to-day implementation within existing organizational structures and technology stacks. The core content and foundational arguments are derived from an exhaustive analysis of practitioner-focused source material that systematically breaks down the Act's operator roles, risk classifications, and staged compliance requirement This internal expertise is treated as the primary data source, representing a consolidated view of applied compliance needs.

The scope of this analysis is confined to the operational mechanics of compliance for high-risk AI systems, which face the most stringent regulatory demands. The paper briefly contextualizes this within the broader Act, including prohibited practices and the emerging regime for general-purpose AI models. The proposed solution is a phased framework that synthesizes the source material's mandates into a coherent action plan, designed for direct utility by risk managers, compliance officers, and technology leaders. By translating legal obligations into a structured sequence of technical and governance activities, this research provides a vital roadmap for building trustworthy, compliant, and competitive AI systems.

2. Research and Analysis

2.1. Current State of Knowledge: Existing GRCA Frameworks and Compliance Obligations

The EU AI Act does not exist in a vacuum; it builds upon and interacts with a mature body of international standards and existing regulations. A foundational understanding of this ecosystem is crucial for effective implementation.

The Act establishes a four-tiered risk pyramid: Unacceptable Risk (prohibited AI practices), High-Risk, Limited Risk (transparency obligations), and Minimal Risk (largely unregulated). The most significant compliance burden falls on the High-Risk category, which includes AI systems used as safety components in critical infrastructure, medical devices, educational and vocational training, employment and workforce management, access to essential public and private services, law

enforcement, migration and border control, and administration of justice and democratic processes. For these systems, the Act mandates a comprehensive lifecycle approach to governance.

Despite this progress, practical guidance on documenting these assessments remains scarce. The dynamic nature of AI, characterized by continuous learning and data drift, challenges static compliance models. As noted by Determann (2024), risk assessments must identify potential harms and liabilities in a way that is defensible against legal challenges, yet many organizations struggle to maintain this documentation in real-time. Recent literature emphasizes the necessity of integrating of implementation frameworks. Research indicates that effective compliance requires a synthesis of existing Information Security Management Systems (ISMS) with new AI-specific extensions (Pötsch, 2024). Furthermore, the importance of harmonized risk assessments, aligning GDPR data protection impact assessments (DPIAs) with the AI Act's fundamental rights impact assessments (FRIAs), is increasingly recognized as a critical efficiency driver (Gruchała et al., 2025).

The existing frameworks that intersect with the EU AI Act include:

- ISO/IEC 42001:2023 (AI Management System - AIMS): This standard provides a model for establishing, implementing, and maintaining an AI management system. It aligns closely with the Act's requirements for a governance framework, risk management, and continuous improvement (Pötsch, 2024).
- NIST AI RMF (Artificial Intelligence Risk Management Framework): While voluntary, the NIST AI RMF's core functions, GOVERN, MAP, MEASURE, and MANAGE, offer a practical structure for operationalizing the Act's risk management system requirements, particularly in mapping known risks and measuring ongoing performance.
- GDPR (General Data Protection Regulation): For AI systems processing personal data, the GDPR's requirements for lawfulness, fairness, transparency, and data minimization remain in full effect. The Act's requirement for a Fundamental Rights Impact Assessment (FRIA) for deployers often complements the GDPR's Data Protection Impact Assessment (DPIA) (Gruchała, Nicosia, & Zięciak, 2025).

The Act's obligations are distributed across a value chain of operators. The Provider, the entity that develops an AI system or places it on the market under its name, bears the primary responsibility for conformity assessment, technical documentation, and post-market monitoring. The Deployer, the entity using an AI system under its authority, has obligations to use the system as intended, ensure human oversight, and conduct fundamental rights impact assessments. Importers and Distributors have duties to verify the Provider's compliance before making systems available in the EU market. A critical nuance is that a Deployer who substantially modifies an AI system's intended purpose or performance can be reclassified as a Provider, inheriting the full spectrum of associated liabilities.

2.2. Practical Gaps & Challenges: Identifying Implementation Hurdles

Despite the clarity of the Act's top-level requirements, organizations face significant practical challenges in implementation. The source material reveals several concrete gaps between regulatory expectation and operational reality.

A typical challenge in assessing AI-related vulnerabilities, threats, and risks is the concrete calculation of potential financial exposure, which is a prerequisite for approving an AI project and allocating an appropriate budget for its governance. A quantitative assessment of potential losses serves as a critical business criterion for making foundational decisions, such as determining the minimum acceptable thresholds for accuracy and other performance metrics, establishing the scope and duration of warranties, and defining specific liability and indemnification clauses in contractual agreements with providers and partners. Fortunately, there are now emerging open-source methodologies that empower AI risk managers to systematically calculate this exposure by modeling ranges of potential financial losses and associating them with the estimated prevalence of successful threat events that could exploit system vulnerabilities (Huwyler, 2025). Moving beyond qualitative checklists, this current practice of quantifying probable losses, based on structured threat models and data-driven analysis that incorporates both empirical studies and calibrated expert estimates, improves organizational decision-making. It provides a defensible, economic rationale for investing in specific technical and procedural controls, for procuring tailored AI insurance policies to transfer residual risk, and for ultimately building a robust corporate defense that can withstand scrutiny in the event of negligence claims or regulatory investigations. A data-driven assessment of risk exposures support the use of the best available information and the risk/control balance calculation to meet the ISO 42001 and ISO 23894 requiremetns. Ultimately, a financially-grounded approach to risk assessment operationalizes and gives tangible meaning to the security and safety principles that underpin the entire paradigm of responsible technology.

A major operational gap lies in the precise definition of a "substantial modification." Many organizations procure off-the-shelf AI solutions and fine-tune them on proprietary data for specific use cases. As the source material notes, "fine-tuning or retraining that materially changes model outputs or risk profile. Repurposing a general-purpose AI for high-risk HR screening" can trigger a shift from Deployer to Provider status. Without clear internal protocols to assess this boundary, companies may inadvertently assume massive compliance liabilities they are unprepared to fulfill. The distinction between a "Provider" and a "Deployer" is legally binary but technically fluid. A company using a third-party model (Deployer) that fine-tunes it on internal data may inadvertently cross the threshold to become a Provider, inheriting full regulatory liability for conformity assessments and quality management.

A significant gap exists between the Act's lifecycle-oriented requirements and the project-based, siloed nature of many existing IT governance and risk management systems. The mandate for a continuous risk management system and post-market monitoring requires a fusion of legal, technical, and operational functions that many organizations' structures do not facilitate (Pötsch,

2024). This is not merely a procedural challenge but a architectural one, requiring the integration of MLOps pipelines with GRC platforms.

The requirement for detailed technical documentation (per Article 11) and automatically generated logs (per Article 12) represents a substantial gap in current practices for many AI development teams. The source material outlines extensive documentation needs, spanning project charters, data sheets, model cards, and assessment report. Most agile development environments are not optimized for producing the rigorous, standardized documentation required for a conformity assessment, creating a risk of development velocity being severely hampered. Accurately classifying a system as "High-Risk" requires precise interpretation of Annex III of the EU AI Act. Misclassification can lead to either dangerous non-compliance (under-classification) or wasted resources on unnecessary controls (over-classification).

The Act requires that high-risk AI systems be designed for "effective human oversight" (Article 14), but provides limited technical guidance on what this means in practice. The gap lies in translating this legal concept into usable interfaces, clear procedures, and trained personnel. Organizations struggle with designing human-in-the-loop workflows that are neither so intrusive as to negate the AI's benefits nor so passive as to constitute "rubber-stamping" (Gikay, Lau, & Sengul, 2023).

AI models are not static; they can degrade or behave unexpectedly as input data changes over time (a phenomenon known as "model drift"). The Act's requirement for continuous post-market monitoring creates a gap for organizations accustomed to one-time, pre-launch testing. Establishing a system to "actively collect, document, and analyze relevant data on AI system performance throughout its lifetime" is a significant technical and resource challenge. Organizations often assume that wrapping a user interface around a General Purpose AI (GPAI) API absolves them of Provider responsibilities. However, if the context or parameters are modified significantly to change the "intended purpose," the integrator may be liable.

Compliance evidence is often scattered. Legal owns the policy, Data Science owns the model weights, and IT owns the logs. This fragmentation makes it impossible to produce the unified technical documentation required for conformity assessments. There is a shortage of "purple teams", cross-functional groups where risk managers understand Python notebooks and data scientists understand fundamental rights. This leads to "box-ticking" compliance that fails to address substantive risks like bias or drift.

3. Proposed Framework for a Phased Compliance Implementation

To address these gaps, a structured, phased framework is proposed, directly derived from the staged compliance approach. This model organizes the Act's myriad requirements into a logical sequence of activities, from initial planning to ongoing maintenance.

Phase 1: Planning (Scoping & Governance)

This foundational phase focuses on understanding what systems are in scope and what roles the organization plays.

- Action 1.1: Create an AI Inventory. Identify all AI systems, models, and datasets used across the organization, including those embedded in third-party software.
- Action 1.2: Classify by Risk. Apply the EU AI Act's risk pyramid to each system in the inventory. Tag systems as Prohibited, High-Risk, Limited Risk, or Minimal Risk.
- Action 1.3: Assign Operator Roles. For each system, determine if the organization acts as a Provider, Deployer, Importer, Distributor, or a combination thereof.
- Action 1.4: Establish Governance. Appoint responsible individuals and committees. Initiate the development of an AI Management System (AIMS), often aligned with ISO/IEC 42001.

Phase 2: Requirements (Gap Analysis & Strategy)

This phase involves assessing the current state against the Act's demands and planning the compliance journey.

- Action 2.1: Conduct a Gap Analysis. For high-risk systems, perform a detailed review against the Act's mandatory requirements (e.g., Risk Management System, Data Governance, Technical Documentation).
- Action 2.2: Develop a Compliance Roadmap. Prioritize gaps, allocate resources, and establish a project plan for achieving compliance, including timelines and milestones.

Phase 3: Design (System & Documentation Engineering)

This is the core technical phase where compliance is engineered into the AI system and its supporting artifacts.

- Action 3.1: Implement a Risk Management System. Establish a continuous process to identify, analyze, evaluate, and mitigate risks throughout the AI lifecycle, including foreseeable misuse.
- Action 3.2: Develop Technical Documentation. Create the comprehensive documentation required by Article 11, covering system architecture, data specifications, training processes, and testing results.
- Action 3.3: Draft Instructions for Use. Prepare clear and complete information for deployers, enabling them to use the system correctly and comply with their own obligations.

Phase 4: Testing (Validation & Verification)

This phase ensures that the system and its supporting processes meet the required standards.

- Action 4.1: Conduct Conformity Assessment. For providers, this is the mandatory process (either internal or involving a Notified Body) to demonstrate compliance before placing a high-risk system on the market.
- Action 4.2: Perform Adversarial Testing. For general-purpose AI models and high-risk systems, conduct "red teaming" to identify and mitigate vulnerabilities.
- Action 4.3: Execute Fundamental Rights Impact Assessment (FRIA). For deployers of high-risk systems, complete this assessment before go-live.

Phase 5: Deployment (Operational Integration)

This phase focuses on launching the system in a compliant manner and ensuring ongoing operational controls.

- Action 5.1: Implement Human Oversight. Design and deploy tools and procedures that allow deployers to effectively oversee the system, interpret outputs, and intervene or halt operation.
- Action 5.2: Register in EU Database. Register high-risk AI systems in the required EU database before deployment.
- Action 5.3: Launch AI Literacy Training. Roll out tailored training programs for all staff interacting with the AI system, from developers to end-users.

Phase 6: Maintenance (Continuous Monitoring & Improvement)

Compliance is not a one-time event. This phase ensures the system remains compliant throughout its lifecycle.

- Action 6.1: Establish Post-Market Monitoring. Set up systems to actively collect and analyze performance data to identify emerging risks, model drift, and serious incidents.
- Action 6.2: Implement an Incident Response Plan. Have a clear process for investigating, mitigating, and reporting serious incidents to authorities within the mandated timelines (e.g., 15 days, or 2 days for critical infrastructure).
- Action 6.3: Manage Updates and Modifications. Any substantial modification to the system triggers a re-assessment of its risk classification and conformity, potentially restarting elements of this framework.

4. Technical and Governance Analysis

The proposed phased framework is not merely a checklist; it represents a fundamental shift in how organizations must manage AI. Its efficacy is supported by its alignment with both the source material's mandates and external scientific research on effective governance.

The primary motivation is regulatory compliance and risk mitigation. Adopting a structured framework is the most defensible approach to avoiding the Act's severe financial penalties and market access restrictions. Beyond compliance, a robust framework enhances trust with customers,

partners, and regulators. It also creates business value by improving the reliability, fairness, and overall quality of AI systems, reducing the long-term costs associated with AI failures and reputational damage (Determann, 2024).

The framework's emphasis on a continuous Risk Management System (RMS) is critical. Research indicates that treating AI risk as a static, pre-launch concern is inadequate. An integrated RMS, as suggested by the framework, allows for the proactive management of dynamic risks like data drift and adversarial attacks (Novelli, Casolari, Rotolo, et al., 2024). This aligns with the NIST AI RMF's "MEASURE" and "MANAGE" functions, creating a feedback loop that connects post-market monitoring back to risk assessment and model retraining.

The framework treats technical documentation not as a one-time report but as a living artifact maintained throughout the lifecycle. This is supported by studies highlighting that documentation, such as model cards and datasheets for datasets, is essential for transparency, auditability, and knowledge transfer within organizations (Golpayegani, Pandit, & Lewis, 2023). Automating the generation of this documentation, "Documentation as Code", integrated into MLOps pipelines, is a key technical strategy to manage this burden without impeding development.

The framework's requirement to "design and deploy" human oversight tools addresses a common weakness. Effective oversight is not just a procedural step but a system design challenge. Research into Human-in-the-Loop (HITL) systems suggests that oversight mechanisms must be context-aware, providing humans with the right information at the right time to make meaningful interventions (Gikay, Lau, & Sengul, 2023). This could involve UI elements that highlight prediction confidence scores or anomaly detection alerts that prompt human review.

Pros and Cons of the Phased Approach:

Pros:

- It breaks down a complex problem into manageable, sequential steps, reducing the likelihood of overlooking critical obligations.
- By first identifying high-risk systems (Phase 1), organizations can focus their compliance resources where they are most needed and where the regulatory burden is highest.
- The structured nature of the framework makes it amenable to partial automation, such as using software tools for inventory management, documentation generation, and monitoring.

Cons:

- Full implementation, particularly for organizations with numerous high-risk systems, requires significant investment in personnel, technology, and time.

- A strictly phased approach may be perceived as conflicting with agile development methodologies. However, this can be mitigated by integrating compliance "gates" within agile sprints rather than viewing it as a linear waterfall process.
- As the Act is new, regulatory guidance and court rulings will evolve. The framework requires a component of adaptability to incorporate new interpretations of key terms like "substantial modification" or "effective human oversight."

The integration of this framework with existing standards like ISO/IEC 42001 is a key success factor. As Pötsch (2024) notes, leveraging an existing Information Security Management System (ISMS) and extending it with AI-specific controls (AIMS) is a pragmatic and efficient path to compliance, avoiding redundant governance structures.

5. Discussion

The analysis demonstrates that the EU AI Act's compliance requirements, while complex, can be systematically operationalized through a structured, phased framework. The proposed model successfully translates the legal text's abstract obligations into a concrete sequence of actions, directly addressing the identified practical gaps. The framework's emphasis on the interplay between continuous risk management, rigorous documentation, and designed-in human oversight is interpreted as the cornerstone of sustainable compliance. Its efficacy lies in its ability to make compliance a traceable and auditable process, moving from a state of reactive interpretation to proactive management.

For practitioners, the implications are clear: a "wait-and-see" approach is fraught with risk. The following actionable recommendations are derived from the framework:

- Immediately initiate a cross-functional effort to catalog all AI systems. This is the non-negotiable first step and often reveals "shadow AI" projects that pose significant unmanaged risk.
- Establish a formal review board or process, involving legal and technical experts, to assess any customization of third-party AI models. This process should document the justification for the chosen role classification to create a defensible audit trail.
- Mandate the use of standardized templates (e.g., based on model cards) within AI development teams. Integrate the completion of these documents as mandatory gates in the CI/CD pipeline.
- For high-risk systems, involve UX designers and domain experts early in the development process to create interfaces that empower human operators, rather than bolting on oversight as an afterthought.

This analysis is subject to several limitations. First, the EU AI Act is a new regulation, and its practical enforcement and interpretation by national authorities and courts remain to be fully seen. The framework may require adjustment as "common specifications" are released by the European

Commission and case law develops. Second, the source material, while comprehensive, represents a specific pedagogical perspective; other expert interpretations may emphasize different aspects or challenges. Finally, the framework is designed to be generalizable, and its application will need to be tailored to the specific context, size, and risk appetite of individual organizations.

This paper's primary contribution is the synthesis of a complex regulatory mandate into a practitioner-oriented implementation blueprint. It bridges the critical gap between the high-level law and the granular, technical, and organizational actions required for compliance. By providing a clear, staged framework and analyzing its components in depth, this research empowers GRCA professionals, risk managers, and technology leaders to navigate the EU AI Act with greater confidence and efficacy, transforming a regulatory challenge into an opportunity to build more robust and trustworthy AI systems.

6. Conclusions

This research has established that compliance with the EU AI Act, particularly for high-risk AI systems, necessitates a methodical and integrated approach. The foundational conclusion of this analysis is that regulatory compliance is not a singular, finite activity but an integrated, end-to-end lifecycle process. This journey begins with the initial strategic planning and scoping of AI systems and extends continuously through their design, development, deployment, and long-term operation, culminating in rigorous post-market monitoring and a commitment to iterative improvement. This lifecycle perspective is critical because it acknowledges that AI systems are dynamic entities whose risks and performance can evolve, necessitating vigilance long after the initial launch.

Within this continuous process, the accurate identification of organizational roles, such as Provider, Deployer, Importer, or Distributor, coupled with a precise risk classification according to the EU AI Act's pyramid, serves as the indispensable bedrock for all subsequent actions. Errors or oversights at this foundational stage are not contained; they propagate through the entire compliance program, creating a cascade of misapplied resources, unmet obligations, and significant legal and financial liability, potentially reclassifying a mere user into a fully liable provider with the stroke of a pen.

For systems deemed high-risk, the framework identifies three non-negotiable pillars that must be engineered into their core: first, a continuous risk management system that proactively identifies and mitigates threats throughout the AI's operational life; second, comprehensive and meticulously maintained technical documentation that provides the necessary evidence for conformity and enables transparency; and third, effectively designed human oversight mechanisms that are embedded within the user interface and operational procedures to ensure meaningful human control.

Ultimately, the adoption of a phased implementation framework, as detailed in this research, provides organizations with a logical, sequential, and actionable path forward. This structured approach enables enterprises to systematically dismantle the complex body of regulatory obligations into manageable components, allowing for the efficient allocation of resources, the clear assignment of responsibilities, and the methodical construction of a verifiable audit trail that can withstand scrutiny from regulators and notified bodies alike.

This paper contributes to the field of applied AI governance by providing a concrete, actionable framework that is directly derived from a detailed analysis of the EU AI Act's operational requirements. It moves the discourse beyond theoretical discussion and high-level principles into the realm of practical implementation, offering a structured methodology that can be adopted and adapted by organizations across industries.

Recommendations for Practitioners

For organizations embarking on their EU AI Act compliance journey, the following steps are critical:

- Conduct an initial AI inventory and risk classification exercise. Identify your top 3-5 highest-risk systems.
- Formally assign accountability for AI governance to a specific function or individual. Begin drafting an AI policy that reflects the Act's risk-based approach.
- Select one high-risk system as a pilot for full implementation of the proposed framework. Use the lessons learned to refine the process before scaling across the organization.
- Invest in AI literacy training for legal, compliance, and risk teams, and simultaneously, provide training on the EU AI Act's requirements for data scientists and developers.

Future Research Directions

As the global regulatory landscape for artificial intelligence rapidly matures beyond the pioneering EU AI Act, several critical and interconnected avenues for future scholarly and applied research emerge, each holding the potential to significantly refine organizational practices and inform subsequent regulatory iterations.

A primary and pressing need lies in conducting rigorous, quantitative studies that measure the real-world cost, time, and resource impact of implementing comprehensive compliance frameworks across organizations of varying sizes, sectors, and technological maturity. Such empirical research would move beyond theoretical models to provide invaluable data for policymakers on the economic burden of compliance and for business leaders seeking to benchmark their own efforts and justify strategic investments in governance infrastructure.

Concurrently, there is a compelling demand for in-depth, qualitative case studies analyzing real-world conformity assessments and regulatory audits as they are conducted under the auspices of

the EU AI Act. These analyses would offer an unprecedented window into the practical enforcement priorities of national authorities and notified bodies, illuminating the interpretive challenges surrounding ambiguous legal concepts like "substantial modification" or "effective human oversight," and thereby providing much-needed clarity to the regulated community. From a technological standpoint, a fertile field for innovation and study involves the further development and validation of automated tools designed for the continuous monitoring of compliance status, real-time bias and drift detection in live models, and the auto-generation of standardized, "machine-readable" technical documentation directly from MLOps pipelines. This research direction is essential for scaling compliance from a manual, labor-intensive process to an integrated, efficient, and sustainable engineering discipline.

Finally, given the increasingly global nature of AI development and deployment, a crucial strategic research avenue involves exploring how a compliance framework originally designed for the EU's risk-based model can be pragmatically extended, adapted, or harmonized to meet the distinct, and sometimes conflicting, requirements of other major jurisdictions, such as the sector-specific approaches emerging in the United States, the principles-based guidelines in Canada, or the state-centric governance models developing in China. This line of inquiry is essential for helping multinational organizations navigate the complex tapestry of global AI regulation without resorting to inefficient, siloed compliance efforts for each market.

7. References

1. Determann, Lothar. "Assessing Impacts and Mitigating Risks." In Research Handbook on Corporate Liability, edited by Martin Petrin and Christian Witting, 2024.
2. Gikay, Asress Adimi, Pin Lean Lau, and Cigdem Sengul. "High-Risk Artificial Intelligence Systems under the European Union's Artificial Intelligence Act: Systemic Flaws and Practical Challenges." SSRN Electronic Journal, 2023. https://doi.org/10.2139/ssrn.4621605.
3. Golpayegani, Delaram, Harshvardhan J. Pandit, and David A. Lewis. "To Be High-Risk, or Not To Be—Semantic Specifications and Implications of the AI Act's High-Risk AI Applications and Harmonised Standards." In Proceedings of the 2023 ACM Conference on Fairness, Accountability, and Transparency, 2023. https://doi.org/10.1145/3593013.3594050.
4. Gruchała, Przemysław, Lucrezia Nicosia, and Monika Zięciak. "Harmonising Risk Assessments for High-Risk AI Systems under the GDPR and the AI Act." Journal of Data Protection & Privacy 8, no. 3 (2025).
5. Huwyler, Hernan. " Quantitative Risk Assessment in R: An Open-Source Convolved Framework for Modeling Uncertainty and Reserves IE Executive Education, 2025. DOI: 10.5281/ZENODO.17687261
6. Novelli, Claudio, Federico Casolari, Antonino Rotolo, Marija Slavkovik, and Giovanni Sartor. "AI Risk Assessment: A Scenario-Based, Proportional Methodology for the AI Act." Digital Society 3, no. 1 (2024). https://doi.org/10.1007/s44206-024-00095-1.

7. Pötsch, Jordan. "Interplay of ISMS and AIMS in Context of the EU AI Act." arXiv preprint arXiv:2412.18670, 2024. https://doi.org/10.48550/arxiv.2412.18670.

Conflicts of Interest: The author declares no conflicts of interest.

Funding: This research received no external funding.

Version: 1.0

Date: 2025-08-09